DOCUMENTO DE CÁTEDRA N°16

TEMA: IoT e IIoT: PROTOCOLOS LIGEROS Y EXPANSIÓN DE LA SUPERFICIE DE ATAQUE

Apertura: URGENT/11 — dos mil millones de dispositivos sin parche

En agosto de 2019, el equipo de investigación de Armis Security publicó una revelación que puso en alerta a los fabricantes de equipos industriales de todo el mundo: URGENT/11, once vulnerabilidades críticas en VxWorks, el sistema operativo de tiempo real (RTOS) más utilizado del planeta, presente en más de 2.000 millones de dispositivos embebidos. Los dispositivos afectados incluían controladores industriales de Siemens, Rockwell Automation y ABB, equipos médicos en hospitales, switches de red industrial en instalaciones críticas y sistemas de control SCADA en infraestructura de energía. Ninguno de estos dispositivos tenía un mecanismo de actualización de firmware remoto seguro. Muchos tenían más de diez años en producción activa sin ningún parche de seguridad aplicado.

El problema revelado por URGENT/11 no era un bug de software aislado que un parche podría solucionar. Era estructural: estos dispositivos nunca fueron diseñados para conectarse a internet, nunca se imaginaron como objetivos de ataque, y por lo tanto no fueron construidos con la capacidad de actualizarse remotamente de forma segura. En 2019 estaban conectados a internet por millones, impulsados por la misma presión de la Industria 4.0 analizada en el Documento N°15: eficiencia operativa, monitoreo remoto, mantenimiento predictivo. La conectividad llegó. La seguridad no.

Este caso define la premisa central de este documento: el ecosistema IoT/IIoT no es simplemente OT conectado a una red IP. Es una clase de dispositivos con un perfil de riesgo estructuralmente diferente al OT clásico: ciclos de vida más cortos que el soporte del fabricante, protocolos diseñados para eficiencia energética y no para seguridad, y una penetración masiva en entornos industriales que históricamente no tenían que defender esa superficie. Cuando estos dispositivos se integran a redes OT que ya hemos estudiado —redes cuyos protocolos de control no tienen autenticación—, el resultado es una superficie de ataque que ningún modelo de amenazas clásico de IT logra mapear completamente.

Ubicación en el Programa: Este Documento N°16 es el segundo de la Unidad 4. El Documento N°15 analizó la convergencia IT/OT como fenómeno arquitectónico: el Modelo Purdue, sus vectores de erosión y los marcos normativos NIST SP 800-82 e ISA/IEC 62443. Este documento profundiza en el ecosistema IoT/IIoT como la manifestación más acelerada y menos controlada de esa convergencia: dispositivos con nuevos protocolos de comunicación, desafíos de seguridad estructurales y una taxonomía de riesgos específica. Los Documentos N°17 y N°18 completarán la Unidad con la doctrina de gestión de riesgos y el análisis forense de los casos históricos.

OBJETIVOS DE APRENDIZAJE

- Diferenciar los conceptos IoT, IIoT y OT clásico en términos de ciclo de vida, protocolos, consecuencias del fallo y capacidad de gestión de seguridad.
- Analizar el funcionamiento técnico y el perfil de seguridad de los protocolos ligeros MQTT, CoAP y OPC-UA, identificando sus vulnerabilidades estructurales en contexto OT.
- Aplicar el análisis de funciones MQTT —publish, subscribe, wildcards, retained messages, LWT— para identificar vectores de ataque específicos sobre brokers IIoT en redes industriales.
- Clasificar los dispositivos IIoT presentes en infraestructura crítica según su categoría y perfil de riesgo OT, identificando los desafíos de seguridad estructurales de cada uno.
- Evaluar el impacto de la incorporación de dispositivos IoT/IIoT en entornos OT y diseñar controles de seguridad compensatorios cuando el reemplazo de dispositivos vulnerables no es inmediatamente posible.

1. IoT, IIoT Y OT CLÁSICO: UN MAPA CONCEPTUAL

Los términos IoT (Internet of Things), IIoT (Industrial Internet of Things) y OT clásico se usan frecuentemente como sinónimos en la literatura de ciberseguridad industrial, pero representan categorías técnicas con perfiles de riesgo distintos. Comprender esas diferencias es el primer paso para gestionar correctamente la superficie de ataque que cada una introduce en una instalación de infraestructura crítica:

Característica	IoT de consumo	IIoT Industrial	OT clásico (PLC/RTU/SCADA)
Ciclo de vida esperado	2 a 5 años. El fabricante planifica reemplazos periódicos.	5 a 15 años. Ciclo mayor que IT pero menor que OT clásico.	15 a 30 años. El activo opera décadas sin reemplazo. El SO embebido puede ser anterior al fin de soporte del fabricante.
Conectividad	WiFi, BLE, ZigBee, NB-IoT. Conectividad IP nativa y obligatoria.	Ethernet IP + protocolo industrial (Modbus TCP, PROFINET, EtherNet/IP). Doble interfaz frecuente.	Fieldbus serial (Modbus RTU, Profibus, Foundation Fieldbus) en Level 1. Ethernet solo en Level 2-3.
Capacidad de actualización (parcheo)	Actualización OTA automática. El fabricante puede emitir y desplegar parches en horas.	Limitada. Requiere ventanas de mantenimiento programadas. Actualización puede interrumpir el proceso.	Mínima o nula. Los parches pueden invalidar la certificación funcional del controlador. Muchos no tienen mecanismo de actualización segura.
Consecuencia del fallo	Inconveniencia del usuario. Sin	Pérdida operativa, impacto económico,	Consecuencia física directa e inmediata:

Característica	IoT de consumo	IIoT Industrial	OT clásico (PLC/RTU/SCADA)
	impacto en infraestructura física.	posible consecuencia física según el proceso controlado.	riesgo para personas, instalaciones y misión. La disponibilidad es la prioridad máxima (tríada AIC).
Gestión de seguridad	Responsabilidad del fabricante. El usuario acepta actualizaciones automáticas.	Responsabilidad compartida fabricante/operador. El operador debe validar cada actualización antes de aplicarla.	Responsabilidad del operador. El fabricante puede no tener soporte activo. El operador decide cuándo y si actualiza.
Autenticación nativa	Variable. Frecuente uso de credenciales por defecto. TLS cuando el fabricante lo implementa.	Variable. Protocolos OT sin autenticación en fieldbus. Autenticación en nivel de aplicación solo en protocolos modernos (OPC-UA).	Sin autenticación en protocolos de fieldbus (Modbus, DNP3, BACnet sin extensiones de seguridad). La confianza se basa en el aislamiento de red.

La consecuencia práctica de esta tabla es que los tres dominios coexisten en instalaciones modernas de infraestructura crítica: las cámaras de seguridad son IoT de consumo, los sensores de proceso son IIoT, y los PLCs son OT clásico. Cuando los tres están en la misma VLAN —o en VLANs con conectividad no controlada entre sí—, la postura de seguridad del sistema es la del componente más débil. Y el componente más débil es siempre el que nadie gestionó de forma explícita.

El fenómeno que describe el caso URGENT/11 no es que los dispositivos IIoT eran vulnerables: es que estaban conectados a redes críticas sin que nadie hubiera realizado una evaluación de riesgo de esa conexión, y sin que existiera un mecanismo para remediar las vulnerabilidades descubiertas una vez que el dispositivo estaba en producción activa. Esa combinación —conectividad no gestionada + vulnerabilidades sin remediación posible— es la característica definitoria del riesgo IIoT en OT.

2. PROTOCOLOS LIGEROS: MQTT, CoAP Y OPC-UA

Así como Modbus domina la fábrica, DNP3 domina la red eléctrica y BACnet domina los edificios, el ecosistema IoT/IIoT ha generado su propio conjunto de protocolos diseñados para un perfil radicalmente diferente al OT clásico: dispositivos con recursos computacionales limitados, redes con ancho de banda reducido, y la necesidad de transmitir pequeños mensajes de telemetría con mínimo overhead. Esa optimización para la eficiencia tiene un costo directo en seguridad.

2.1. Mapa comparativo de protocolos ligeros

Protocolo	Modelo de comunicación	Capa / Puerto	Seguridad nativa	Uso típico en OT/IIoT
MQTT v5.0	Publish/Subscribe sobre broker central. El productor publica a un tópico; los consumidores suscriben al tópico.	TCP. Puerto 1883 (sin TLS) / 8883 (con TLS)	Sin autenticación en el estándar base (allow_anonymous). Usuario/contraseña opcionales, en texto claro si no usa TLS. TLS opcional.	Telemetría de sensores IIoT. Integración con cloud (AWS IoT, Azure IoT Hub). Datos de proceso hacia historian.
CoAP	Request/Response similar a HTTP REST. Diseñado para microcontroladores con <10 KB de RAM.	UDP. Puerto 5683 (sin DTLS) / 5684 (con DTLS)	Sin autenticación en el estándar base. DTLS opcional pero raramente implementado en dispositivos constrained por overhead de cómputo.	Sensores con recursos muy limitados. Redes de sensores inalámbricos. Medidores inteligentes de energía.
AMQP 1.0	Message Queue con broker. Más robusto que MQTT: mensajes con confirmación, colas persistentes, routing complejo.	TCP. Puerto 5672 (sin TLS) / 5671 (con TLS)	Autenticación SASL (usuario/contraseña, certificados). TLS opcional. Mejor perfil de seguridad que MQTT pero mayor overhead.	Integración empresarial IT/OT. Sistemas de mensajería entre aplicaciones de mayor complejidad. Bus de integración industrial.
OPC-UA	Client/Server + Publish/Subscribe. Modelo de objetos rico. Estándar de integración IT/OT de referencia.	TCP. Puerto 4840 (configurable)	Autenticación con certificados X.509. Cifrado TLS. Firma digital de mensajes. El protocolo OT/IIoT con mejor perfil de seguridad nativo.	Integración IT/OT a nivel de historian y SCADA. Protocolo de elección para la capa de integración segura entre OT e IT en instalaciones modernas.

La tabla evidencia una asimetría fundamental: los protocolos optimizados para dispositivos constrained (MQTT, CoAP) tienen el menor perfil de seguridad nativo, mientras que el protocolo con el mejor perfil de seguridad (OPC-UA) requiere mayor capacidad computacional y de memoria. La elección del protocolo en entornos IIoT no

es solo técnica: es una decisión de riesgo que debe hacerse de forma explícita y documentada.

2.2. MQTT: análisis de funciones y vectores de ataque

MQTT es el protocolo más utilizado en el ecosistema IIoT y el que más frecuentemente aparece en incidentes de seguridad documentados en entornos industriales. Su modelo publish/subscribe y su ligereza lo hacen ideal para telemetría de sensores, pero sus características avanzadas —wildcards, retained messages, Last Will and Testament— crean vectores de ataque específicos que el analista de Ciberdefensa debe conocer:

Función MQTT	Mecanismo técnico	Vulnerabilidad en contexto OT	Contramedida
Publish (sin autenticación)	Un cliente publica un mensaje a un tópico del broker. Sin autenticación, cualquier cliente en la red puede publicar a cualquier tópico, incluyendo tópicos de control de actuadores.	Un adversario en la red OT puede publicar comandos a tópicos que los actuadores IIoT escuchan, ejecutando acciones físicas no autorizadas: abrir válvulas, cambiar setpoints, activar actuadores.	Autenticación obligatoria (certificados X.509 por dispositivo o usuario/contraseña con TLS). ACLs que restringen qué clientes pueden publicar a qué tópicos.
Subscribe (sin autorización)	Un cliente se subscribe a un tópico y recibe todos los mensajes publicados. Sin autorización, cualquier cliente puede subscribirse a cualquier tópico, incluyendo los de datos de proceso.	Un adversario puede subscribirse al broker y recibir en tiempo real todos los datos del proceso: temperatura, presión, estado de válvulas. Reconocimiento completo del proceso sin autenticación.	ACLs de solo lectura para clientes de monitoreo. Tópicos de control solo accesibles para publicación por clientes con certificado válido. Broker en VLAN separada con firewall.
Wildcard subscription (#)	MQTT permite subscribirse a todos los tópicos simultáneamente con el wildcard “#”. Un único subscribe “#” recibe todos los mensajes de todos los tópicos del broker.	Un adversario puede recolectar todo el estado del proceso en una sola operación de reconocimiento, equivalente funcional al broadcast Who-Is de BACnet: inventario completo del sistema en segundos.	Deshabilitar wildcards para clientes no administrativos en la configuración del broker. ACLs restrictivas que limiten el scope de cada cliente al conjunto mínimo de tópicos necesarios.
Retained messages	Un mensaje publicado con el flag “retain” es almacenado por el broker y entregado a cualquier nuevo subscriber que se conecte, aunque el mensaje sea antiguo.	El adversario puede publicar un retained message malicioso en un tópico de control. Cada dispositivo que se conecte posteriormente al broker recibirá el comando malicioso, incluso tras la	Monitorear y auditar retained messages en tópicos críticos. Configurar expiración automática. No usar retained messages en tópicos de control de actuadores.

Función MQTT	Mecanismo técnico	Vulnerabilidad en contexto OT	Contramedida
		desconexión del atacante.	
Last Will and Testament (LWT)	Al conectarse, un cliente registra un mensaje que el broker publicará automáticamente si la conexión se interrumpe abruptamente, como mecanismo de notificación de fallo.	Un adversario puede registrar un LWT malicioso en un tópico de control al conectarse. Al desconectarse abruptamente, el broker publica automáticamente el comando como si fuera un evento de sistema legítimo.	No exponer tópicos de control a LWT de clientes no privilegiados. Validar el contenido del LWT en la capa de aplicación del receptor antes de ejecutar cualquier acción física.

Nota de Ciberdefensa — MQTT sin autenticación: el protocolo que conecta el IIoT al OT sin preguntar quién eres

La configuración por defecto del broker MQTT más utilizado del mundo —Eclipse Mosquitto— tiene allow_anonymous = true: cualquier cliente en la red puede conectarse, publicar y subscribirse sin presentar credencial alguna. Esta no es una vulnerabilidad: es una decisión de diseño orientada a simplificar el despliegue en entornos de laboratorio y desarrollo. El problema es que esa configuración llega a producción.

El motor de búsqueda Shodan indexa brokers MQTT accesibles desde internet en el puerto TCP 1883. La búsqueda “port:1883” muestra miles de brokers públicamente accesibles, muchos de ellos con tópicos de datos industriales visibles sin autenticación. Algunos exponen telemetría de instalaciones identificables: lecturas de sensores de temperatura de edificios, datos de consumo eléctrico, estados de control de HVAC.

En el contexto de una instalación de Defensa, la primera acción ante cualquier broker MQTT en producción debe ser verificar tres condiciones: (1) que allow_anonymous = false en la configuración del broker; (2) que el puerto 1883 no es accesible desde ninguna red fuera de la VLAN donde está el broker; (3) que existen ACLs definidas explícitamente para cada cliente, con el principio de menor privilegio aplicado a los tópicos de publicación. La ausencia de cualquiera de estas tres condiciones es una vulnerabilidad crítica, no una configuración suboptimal.

3. EXPANSIÓN DE LA SUPERFICIE DE ATAQUE: TAXONOMÍA DE DISPOSITIVOS IIoT EN INFRAESTRUCTURA CRÍTICA

La superficie de ataque OT en una instalación moderna no está definida solo por los PLCs, RTUs y HMIs que sus ingenieros conocen y gestionan. Está definida también —y crecientemente— por una taxonomía de dispositivos IoT e IIoT que se incorporaron progresivamente a la red sin una evaluación sistemática de su perfil de riesgo. La siguiente tabla clasifica las categorías de dispositivos IIoT más frecuentes en instalaciones de infraestructura crítica y gubernamentales:

Categoría	Ejemplos típicos	Conectividad	Perfil de riesgo OT
Sensores de campo conectados	Sensores de temperatura, presión y vibración con módulo WiFi o 4G para telemetría	WiFi 802.11 o 4G/LTE además de fieldbus serial	Dispositivos en Level 1 con conectividad IP. Si están en la misma red que PLCs, son vectores de entrada al nivel de control más crítico. URGENT/11 afectó directamente a esta categoría.
Medidores inteligentes	Smart meters de energía eléctrica, agua y gas. Medidores de calidad de energía con conectividad IP.	RF (ZigBee, LoRaWAN) o Ethernet. Algunos con 4G.	Generan perfiles de consumo con valor de inteligencia para un adversario estatal. Su compromiso puede revelar patrones operativos, ciclos de actividad y capacidades de la instalación.
Cámaras IP y videovigilancia	IP cameras perimetrales, PTZ remotas, grabadores NVR conectados a la red	Ethernet o WiFi. Puerto RTSP/HTTP expuesto.	Frecuentemente conectadas a la misma VLAN que el OT de gestión del edificio. Historial crítico de vulnerabilidades (Mirai 2016, URGENT/11). Compromiso puede proveer acceso lateral a la red OT.
Gateways de protocolo	Convertidores Modbus-TCP/IP, convertidores serial-Ethernet, routers industriales con módulo celular	Ethernet + fieldbus serial. Algunos con 4G/LTE.	Dispositivos de Level 1-2 con interfaces duales. Son nodos de convergencia entre el fieldbus sin autenticación y la red IP. Comprometidos, el adversario tiene acceso directo a los PLCs del Level 1.
Herramientas de acceso remoto en HMIs	TeamViewer, VNC, AnyDesk instalados en estaciones de ingeniería y HMIs por técnicos de campo para soporte remoto	Internet. Frecuentemente con credencial débil o sin MFA.	Herramientas de administración remota con acceso privilegiado a dispositivos OT. Frecuentemente instaladas para conveniencia en una intervención y no desinstaladas. Acceso directo al Level 2 desde internet.
Controladores de acceso físico (PACS)	Paneles PACS, lectores RFID con IP, controladores de puertas de zona restringida	Ethernet/WiFi	Revisados en el Doc. N°14 (Wiegand/OSDP). Su compromiso puede otorgar acceso físico a zonas con infraestructura OT crítica. La convergencia lógica-física los convierte en vectores bidireccionales.

Nota de Ciberdefensa — El módulo celular invisible: cómo un módem 4G crea un bypass del firewall perimetral

El vector de ataque más frecuentemente subestimado en instalaciones industriales es el módem celular instalado por un técnico de campo para acceso de emergencia a una RTU remota o para telemetría de un sensor nuevo. El proceso típico: el técnico instala el módulo, configura la SIM, verifica que los datos llegan a la plataforma, y lo documenta en su informe de mantenimiento. Nadie en el equipo de Ciberdefensa lo sabe.

El resultado es un dispositivo en Level 1 del Modelo Purdue con una interfaz de red que no pasa por ningún firewall corporativo, no aparece en ningún inventario de activos de red, y no es gestionado por ningún proceso de seguridad. El dispositivo es directamente accesible desde internet a través de la red del operador celular.

La contramedida técnica tiene tres componentes: (1) APN privado del operador celular, que asigna a los dispositivos IPs privadas no accesibles desde internet público; (2) VPN con terminación en la DMZ OT de la instalación, de modo que el acceso celular sea gestionado igual que el acceso remoto de un contratista; (3) inventario activo de SIMs mediante proceso de aprobación previa a cualquier instalación de módulo celular en la red OT. Sin este proceso, el inventario de superficie de ataque OT nunca es completo.

4. DESAFÍOS DE SEGURIDAD ESTRUCTURALES DEL ECOSISTEMA IoT/IIoT

Los dispositivos IoT e IIoT comparten cuatro desafíos de seguridad estructurales que los diferencian del OT clásico y del IT corporativo. Son estructurales porque no derivan de una decisión de implementación incorrecta: están incorporados al diseño del dispositivo y no pueden remediarse con un parche de configuración. Comprender su mecanismo técnico es el requisito previo para diseñar controles compensatorios eficaces:

Desafío estructural	Mecanismo técnico	Impacto en OT	Contramedida
Credenciales por defecto	Los dispositivos IIoT se envían con credenciales de fábrica (admin/admin, admin/1234, root/root). Los operadores no las cambian por desconocimiento o porque el proceso de onboarding no lo exige. Mirai (2016) explotó exactamente este vector para comprometer 600.000 dispositivos IoT en 72 horas.	Un adversario puede acceder al dispositivo IIoT con credenciales públicas disponibles en la documentación del fabricante y usarlo como punto de entrada a la red OT donde está instalado.	Proceso de onboarding que exija el cambio de credenciales antes de la conexión a la red de producción. Escaneo periódico de credenciales por defecto. Política de contraseña mínima definida y documentada.
Firmware sin firma y sin mecanismo de actualización segura	Los dispositivos IoT/IIoT legacy no implementan firma criptográfica del firmware. Cualquier binario puede instalarse si el adversario tiene acceso	Un adversario que compromete el canal de actualización puede instalar malware persistente en miles de	Verificar que el proveedor implementa firma de firmware con clave privada protegida. Actualizar firmware

Desafío estructural	Mecanismo técnico	Impacto en OT	Contramedida
	al mecanismo de actualización. URGENT/11 (2019): los dispositivos afectados no podían parchearse de forma masiva ni verificable.	dispositivos simultáneamente, sin detección visible por el operador.	solo a través de canales autenticados. Priorizar reemplazo de dispositivos sin capacidad de actualización segura en el plan de renovación de activos.
Ciclo de vida mayor que el soporte del fabricante	Los dispositivos OT/IIoT tienen ciclos de vida de 10 a 25 años. Los fabricantes abandonan el soporte de seguridad en 3 a 7 años. Resultado: dispositivos en producción activa con CVEs públicos y sin parche disponible.	El adversario puede explotar vulnerabilidades conocidas y documentadas contra dispositivos sin parche. No se necesita un zero-day: los CVEs son públicos y buscables en bases de datos como ICS-CERT.	Segmentación estricta de dispositivos sin soporte como control compensatorio. Monitoreo específico del tráfico desde y hacia esos dispositivos. Planificación presupuestaria para reemplazo antes del fin de soporte.
Dispositivos constrained: imposibilidad de TLS completo	Los microcontroladores de bajo consumo (ARM Cortex-M0/M3) no tienen potencia de cómputo suficiente para TLS con cifrado RSA/AES-256. Muchos implementan TLS 1.0 o envían datos en texto claro. CoAP con DTLS raramente se implementa en la práctica.	Las comunicaciones de estos dispositivos viajan en texto claro sobre la red. Un adversario con acceso a la red puede interceptar credenciales, datos del proceso y comandos de control sin necesidad de romper ningún cifrado.	Usar TLS 1.3 (optimizado para dispositivos constrained) o DTLS para UDP. Para dispositivos que no pueden soportar TLS, segmentación de red en VLAN aislada con monitoreo estricto de todo el tráfico entrante y saliente.

Nota de Ciberdefensa — Shodan para blue team: auditar la exposición pública de dispositivos IIoT propios

Shodan es frecuentemente descripto como «el buscador de dispositivos conectados a internet». Para el profesional de Ciberdefensa, es una herramienta de auditoría de exposición: permite verificar qué dispositivos IIoT de la propia organización son accesibles desde internet antes de que un adversario los descubra.

Las búsquedas más relevantes para infraestructura crítica incluyen: “port:1883” para brokers MQTT sin TLS; “port:47808” para dispositivos BACnet (revisado en Doc. N°14); “port:502” para dispositivos Modbus/TCP; “port:5000 Siemens” para paneles HMI Siemens SIMATIC; y el nombre de la organización o el rango IP público de la instalación para identificar cualquier dispositivo expuesto.

El protocolo de uso para un equipo de Ciberdefensa es: (1) obtener el rango de IPs públicas asignadas a la organización; (2) ejecutar la búsqueda Shodan sobre ese rango; (3) para cada resultado, identificar el dispositivo, su ubicación en el Modelo Purdue y la justificación

operativa de su exposición pública; (4) cualquier dispositivo OT accesible públicamente sin justificación documentada es una vulnerabilidad crítica que debe ser remediada antes de cualquier otra acción.

La ausencia de resultados Shodan para el rango de la organización no es garantía de seguridad: Shodan no indexa todos los dispositivos, y los módulos celulares (4G) tienen IPs del operador celular, no de la organización. La búsqueda Shodan es una condición necesaria de la auditoría de superficie de ataque, no suficiente.

5. ACTIVIDADES DE VERIFICACIÓN Y ANÁLISIS

1. Análisis de MQTT — configuración segura vs. insegura en planta de tratamiento de agua

Una planta de tratamiento de agua usa un broker MQTT (Eclipse Mosquitto) instalado en un servidor en Level 3 para agregar datos de 120 sensores IIoT. El broker está configurado con allow_anonymous = true y sin TLS. El servidor broker tiene dos interfaces de red simultáneas: una en la VLAN OT y otra en la VLAN IT corporativa para que el sistema de gestión energética en Level 4 pueda subscribir a los tópicos de consumo.

(a) Identifique el modo de integración IT/OT que esta arquitectura representa (con referencia al Doc. N°15, Sección 3) y los vectores de erosión del Modelo Purdue presentes. Justifique cuál es el riesgo principal de la doble interfaz del servidor broker.

(b) Describa al menos tres ataques específicos que un adversario en la red IT podría ejecutar contra este broker MQTT. Para cada ataque indique: la función MQTT explotada (de la Tabla de la Sección 2.2), el tópico MQTT objetivo, y el impacto sobre el proceso de tratamiento de agua.

(c) Rediseñe la arquitectura para eliminar los vectores identificados: reubicación del broker en la DMZ OT, configuración de autenticación y TLS en Mosquitto, definición de ACLs por rol de cliente, y cómo el sistema de gestión energética en Level 4 accedería a los datos sin conectividad directa al broker OT.

2. Auditoría de superficie de ataque IIoT en instalación de Defensa

Un inventario de una instalación de Defensa descubrió los siguientes dispositivos IIoT/IoT en su red: (1) 12 cámaras IP de vigilancia perimetral con firmware de 2016, sin actualizaciones disponibles del fabricante, conectadas a la VLAN OT del edificio. (2) 8 sensores de temperatura IIoT con módulo WiFi y 4G simultáneamente, instalados en los generadores de emergencia. (3) Un gateway Modbus-TCP instalado por el técnico de mantenimiento en el cuadro eléctrico del Level 1, con una app de telemetría que envía datos a la plataforma cloud del fabricante. (4) El HMI del SCADA del generador tiene TeamViewer instalado para soporte técnico remoto.

(a) Clasifique cada uno de los 4 dispositivos según la taxonomía de la Tabla de la Sección 3, identificando la categoría, el perfil de riesgo específico y el desafío estructural de seguridad que representa según la Sección 4.

(b) Priorice los cuatro dispositivos por orden de riesgo para la misión de la instalación, justificando la prioridad con referencia a la tríada AIC y al Security Level del ISA/IEC 62443 que debería aplicar a la zona donde está cada uno.

(c) Para el dispositivo de mayor prioridad, diseñe el plan de mitigación completo: controles técnicos inmediatos, controles compensatorios mientras no se puede eliminar el riesgo, y criterio de aceptación del riesgo residual.

3. Comparativa de protocolos — MQTT vs. OPC-UA para integración IT/OT en planta de generación eléctrica

Un integrador de sistemas propone dos opciones para conectar datos de proceso (PLCs del Level 1) con el sistema de analytics empresarial del Level 4. Opción A: broker MQTT en Level 3 al que los PLCs (con módulo IIoT) publican sus datos, y al que el sistema de analytics subscribiría. Opción B: historian con OPC-UA Server en Level 3, y el sistema de analytics hace queries OPC-UA Client a través de un conduit en la DMZ 3.5.

(a) Compare las dos opciones usando la Tabla de Protocolos de la Sección 2.1: autenticación nativa, cifrado en tránsito, modelo de comunicación y riesgo de bidireccionalidad no intencional. Identifique para la Opción A la función MQTT que podría generar bidireccionalidad no intencional.

(b) Identifique cuál opción cumple mejor con los principios de segmentación del Modelo Purdue y justifique la respuesta. Indique qué nivel Purdue ocupa el broker MQTT en la Opción A y dónde debería estar reubicado para no erosionar el Modelo Purdue.

(c) Para la opción que seleccione como más segura, diseñe los controles adicionales que la harían apta para una instalación de Defensa con Security Level 3 (ISA/IEC 62443). Indique autenticación, cifrado, segmentación de red y monitoreo específico.

4. Caso integrador — URGENT/11 y plan de remediación con controles compensatorios

Un análisis de vulnerabilidades en la instalación de Defensa de los ejercicios anteriores identificó los siguientes hallazgos: tres PLCs Siemens S7-300 (firmware 2011) y dos switches industriales Hirschmann, todos con VxWorks afectado por URGENT/11 (CVEs críticos con puntuación CVSS 9.8). El fabricante no tiene parche disponible para esas versiones de firmware. El jefe de la sección de Ciberdefensa debe presentar un plan de mitigación al comandante en 48 horas.

(a) Explique por qué la remediación convencional (parcheo del sistema operativo) no es aplicable en este caso, haciendo referencia al desafío estructural de ciclo de vida de la Sección 4 y al impacto de una actualización no validada sobre un controlador en producción activa.

(b) Diseñe un plan de mitigación basado exclusivamente en controles compensatorios (compensating controls) que no requiera el reemplazo inmediato de los dispositivos afectados. El plan debe incluir: segmentación de red de los dispositivos vulnerables, reglas de firewall específicas, restricción de protocolos habilitados, y criterios de alertas en el IDS.

(c) Redacte la sección de riesgo residual del informe al comandante: qué riesgo permanece tras los controles compensatorios, bajo qué condiciones ese riesgo se volvería inaceptable y cuál es el criterio de decisión para el reemplazo de hardware. Relacione la respuesta con el Security Level ISA/IEC 62443 que debería tener esa zona de la instalación.

6. GLOSARIO MÍNIMO

Término	Definición
AMQP (Advanced Message Queuing Protocol)	Protocolo de mensajería orientado a colas (puerto TCP 5671/5672). Más robusto que MQTT: incluye confirmación de mensajes, colas persistentes y autenticación SASL. Mayor overhead que MQTT; usado en integración empresarial IT/IIoT.
Broker MQTT	Componente central del modelo publish/subscribe MQTT. Recibe los mensajes de los publicadores (sensores), los almacena temporalmente y los reenvía a los subscriptores (sistemas de monitoreo). Es el nodo de mayor criticidad de una arquitectura MQTT: su compromiso afecta a todos los clientes conectados.
CoAP (Constrained Application Protocol)	Protocolo de comunicación ligero (RFC 7252) para microcontroladores con recursos mínimos de cómputo y memoria. Opera sobre UDP (puerto 5683 sin DTLS, 5684 con DTLS). Modelo Request/Response similar a HTTP REST. DTLS raramente implementado en dispositivos constrained reales.
Credenciales por defecto	Combinación de usuario y contraseña (frecuentemente admin/admin, root/root o variantes) con la que los dispositivos IoT/IIoT salen de fábrica. Su no modificación antes de la conexión a la red de producción es el vector más explotado en incidentes de seguridad IoT (botnet Mirai, 2016).
DTLS (Datagram Transport Layer Security)	Variante del protocolo TLS adaptada para protocolos de transporte UDP. Provee autenticación y cifrado para CoAP y otros protocolos UDP. Requiere mayor overhead de cómputo que el protocolo sin seguridad; raramente implementado en dispositivos IoT constrained de producción.
IIoT (Industrial Internet of Things)	Subconjunto del IoT aplicado a entornos industriales y de infraestructura crítica. Incluye sensores de proceso, gateways de protocolo, actuadores conectados y medidores inteligentes. Ciclo de vida intermedio (5-15 años) entre el IoT de consumo y el OT clásico.
IoT (Internet of Things)	Conjunto de dispositivos electrónicos físicos con conectividad a internet y capacidad de recopilar y transmitir datos. En el contexto de seguridad OT, representa dispositivos con ciclos de vida cortos, actualización OTA y consecuencias de fallo limitadas al usuario, en contraste con el IIoT y el OT clásico.
Mirai (botnet)	Botnet documentada en 2016 que comprometió más de 600.000 dispositivos IoT (cámaras IP, routers) explotando credenciales por defecto vía protocolo Telnet. Ejecutó el mayor ataque DDoS documentado hasta ese momento (1,2 Tbps). Define el caso paradigmático del riesgo de credenciales por defecto en IoT.
MQTT (Message Queuing Telemetry Transport)	Protocolo de mensajería publish/subscribe diseñado para dispositivos con recursos limitados (ISO/IEC 20922). Opera sobre TCP (puerto 1883 sin TLS, 8883 con TLS). Sin autenticación en su configuración por defecto. Protocolo dominante en telemetría IIoT e integración con plataformas cloud industriales.

Término	Definición
OPC-UA (OPC Unified Architecture)	Estándar de comunicación para integración IT/OT (IEC 62541) que incluye autenticación con certificados X.509, cifrado TLS y firma digital de mensajes. Modelo Client/Server y Publish/Subscribe. Protocolo de referencia para integración segura entre historian/SCADA (Level 3) y sistemas IT (Level 4).
RTOS (Real-Time Operating System)	Sistema operativo de tiempo real diseñado para garantizar respuestas determinísticas a eventos externos en intervalos de tiempo definidos. Ejemplos: VxWorks (Wind River), QNX, FreeRTOS. Presente en PLCs, controladores de campo y gateways IIoT. Ciclos de vida muy largos; actualizaciones de seguridad raramente posibles.
URGENT/11	Conjunto de once vulnerabilidades críticas (CVE-2019-12255 a CVE-2019-12265) en VxWorks RTOS, publicadas por Armis Security en agosto de 2019. Afectó a más de 2.000 millones de dispositivos incluyendo controladores industriales Siemens, Rockwell y ABB. Define el caso paradigmático del problema estructural de parcheo en dispositivos IIoT de ciclo de vida largo.

REFERENCIAS BIBLIOGRÁFICAS

NIST. (2019). Considerations for Managing Internet of Things (IoT) Cybersecurity and Privacy Risks (NISTIR 8228). National Institute of Standards and Technology.

Armis Security. (2019). URGENT/11: Critical VxWorks Vulnerabilities Expose a Wide Range of Critical Infrastructure to Remote Attack (CVE-2019-12255 to CVE-2019-12265). Armis Research.

OASIS. (2019). MQTT Version 5.0 Specification. OASIS Standard MQTTv5.

IETF. (2014). RFC 7252: The Constrained Application Protocol (CoAP). Internet Engineering Task Force.

OPC Foundation. (2017). OPC Unified Architecture Specification Part 2: Security Model. OPC Foundation.

Claroty. (2023). State of XIoT Security Report, 2H 2022. Claroty Research.

Knapp, E. D., & Langill, J. T. (2015). Industrial Network Security (2da ed.). Syngress. Capítulo 4: Wireless and IoT Security.

Stouffer, K., et al. (2023). Guide to Operational Technology (OT) Security (NIST SP 800-82 Revision 3). NIST. Sección 2.7: IoT and IIoT in OT Environments.

Cátedra Tecnología Operativa (2026). Documento de Cátedra N°15: Convergencia IT/OT: Desafíos de Integración y la Industria 4.0. FADENA.